

Firmware 7.15 · Block 2 audit report

Transport buffers, Initialize, protected Ping and workflow authority · 22 September 2026

Review judgment: ready for final review of this bounded surface. A Copilot response with zero findings cannot be guaranteed or proved before the review is delivered. No Copilot review was requested for this report.

Identity and method

Current candidate: `audit/715-scope-repair @ 614425a2a14d0113de251e7944118e47f31f5265`. The review PR is [#850](#), based on that exact commit. The canonical product branch `release/7.15 @ af979cd509` is a separate, divergent line and has not been promoted.

Counts below come from `git show --format= --numstat --no-renames <commit>`. Added and deleted lines include tests and documentation. The Ping commit includes a Git submodule pointer as `+1/-1`. A line edited in several commits is counted in each commit; the totals cannot be read as the net candidate diff. This report covers the six original Block 2 commits and six later interaction commits, rather than the full 7.15 product diff.

The review PR itself initially added a 75-line handoff document and no code. This report and the SOP update are additional review artifacts; their final PR line count is shown by GitHub's live PR diff, not folded into historical firmware totals below.

Review-artifact starting head: `2bc83b1e5fc03c951d8b106edbac0f184abf77b5`. The PDF and SOP change are its documentation-only successor. Use the linked PR for their final head and current review diff.

Candidate dependency pins

Submodule	Commit at 614425a2a
code-signing-keys	a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec
deps/crypto/trezor-firmware	8a392f70a5d5575ece3dfb35f115d4a4b27f497c
deps/device-protocol	27d3fa1f6215139cde6411f9a2882f36bb373fc9
deps/googletest	7888184f28509dba839e3683409443e0b5bb8948
deps/python-keepkey	b76ee610dd18934ee3aeeb36cfc541e8799eb46d
deps/qrenc/QR-Code-generator	6dfbfdad5d9303ed190d1c3cb7bec34b565b6ce8
deps/sca-hardening/SecAESSTM32	71d356a1141624994cf613bd2d2583892e8e6d5a

At a glance

Group	Commits	Cumulative added	Cumulative deleted	Purpose
Original Block 2	6	+260	-37	Direct bounded fixes and their tests/receipts

Group	Commits	Cumulative added	Cumulative deleted	Purpose
Later interactions	6	+711	-108	Shared dispatch, signing authority and timer behavior; entire commit counts, including work outside Block 2

Original Block 2 changes

Commit	Change	Files	Added	Deleted
71ee8c0bc	P02-001 Tiny credential lifetime	6	+104	-3
f20c2497a	P02-002 Initialize workflow abort	4	+40	-21
041a23d5c	P02-003 Receive packet lifetime	4	+79	-3
5b2a62ce0	Protected Ping response	2	+3	-1
32c655531	Terminal tiny failure unwind	3	+28	-5
cb5650490	Terminal rejection formatting	1	+6	-4

Commit totals: +260 / -37. These are cumulative per-commit line counts, not a net diff.

P02-001 Tiny credential lifetime 71ee8c0bc

The tiny-message decoder and immediate readers retained prior credential bytes. The change erases tiny decode storage before reception, after malformed input and after copy-out, and wipes caller-owned PIN and passphrase copies. The UDP regression proves a later empty acknowledgement cannot expose the previous passphrase; it failed before this commit and passed after.

File	Added	Deleted
docs/release/audit-units/P02-001-tiny-lifetime.md	+27	-0
lib/board/confirm_sm.c	+1	-0
lib/board/messages.c	+10	-3
lib/firmware/passphrase_sm.c	+1	-0
lib/firmware/pin_sm.c	+1	-0
unittests/firmware/usb_rx.cpp	+64	-0

P02-002 Initialize workflow abort f20c2497a

Initialize previously stopped only selected workflows, leaving Binance, Osmosis, THORChain and MAYAChain sessions live. It now calls the central workflow abort while preserving the soft-clear cached-PIN policy. The native fixture reproduced surviving sessions before the fix and passed afterward.

File	Added	Deleted
docs/release/audit-units/P02-002-initialize-abort.md	+21	-0
lib/firmware/fsm.c	+0	-13
lib/firmware/fsm_msg_common.h	+2	-6
unittests/firmware/fsm.cpp	+17	-2

P02-003 Receive packet lifetime 041a23d5c

After delivery, persistent UDP and device USB packet buffers kept the received bytes. The change wipes each packet after synchronous callback consumption, including device short-read paths. A UDP callback regression failed on the base and passed with the fix; device callback paths were source reviewed and built for ARM.

File	Added	Deleted
docs/release/audit-units/P02-003-packet-lifetime.md	+23	-0
lib/board/udp.c	+3	-0
lib/board/usb.c	+14	-3
unittests/firmware/usb_rx.cpp	+39	-0

Protected Ping response 5b2a62ce0

Ping initialized its response before a protected confirmation, allowing the response storage to be reused while the handler waited. It now initializes the response after confirmation. This commit also advances the pinned Python client; the later full candidate CI validates the combined pin.

File	Added	Deleted
deps/python-keepkey	+1	-1
lib/firmware/fsm_msg_common.h	+2	-0

Terminal tiny failure unwind 32c655531

A malformed or unexpected tiny message could leave its suspended handler waiting or send another failure. The change records terminal rejection, stops the tiny receive pump and returns a cancellation path after one failure. The later formatting commit only reshapes these calls.

File	Added	Deleted
include/keepkey/board/messages.h	+3	-0
lib/board/messages.c	+24	-5
lib/board/usb.c	+1	-0

Terminal rejection formatting cb5650490

Formats the failure calls added by the preceding unit. It changes no intended behavior and is included to account for every original Block 2 commit.

File	Added	Deleted
lib/board/messages.c	+6	-4

Later interaction changes

Commit	Change	Files	Added	Deleted
4309ef671	Rejected transport messages	2	+50	-3
0a7e0cf4a	Validated workflow progress	19	+335	-71
b770928ba	Protected Ping and stale signing	2	+24	-0
2bd12230f	Top-level dispatch boundary	5	+67	-7
d4aa26f91	Dispatch session authority	3	+110	-22
c3ec59c35	Cross-workflow acknowledgements	7	+125	-5

Commit totals: +711 / -108. These are cumulative per-commit line counts, not a net diff.

Rejected transport messages 4309ef671

Keeps an in-progress setup ceremony intact when a transport message is rejected; adds FSM regression coverage.

File	Added	Deleted
lib/firmware/fsm.c	+13	-3
unittests/firmware/fsm.cpp	+37	-0

Validated workflow progress 0a7e0cf4a

Renews the auto-lock timer only for accepted workflow progress, with tests for host-driven messages and active ceremonies.

File	Added	Deleted
docs/release/audit-units/autolock-workflow-progress.md	+21	-0
include/keepkey/board/usb.h	+5	-0
include/keepkey/firmware/home_sm.h	+2	-1
lib/board/usb.c	+6	-0
lib/firmware/ethereum.c	+2	-0
lib/firmware/fsm.c	+0	-11
lib/firmware/fsm_msg_binance.h	+1	-0
lib/firmware/fsm_msg_cosmos.h	+1	-0
lib/firmware/fsm_msg_eos.h	+5	-0

File	Added	Deleted
lib/firmware/fsm_msg_mayachain.h	+1	-0
lib/firmware/fsm_msg_osmosis.h	+1	-0
lib/firmware/fsm_msg_tendermint.h	+1	-0
lib/firmware/fsm_msg_thorchain.h	+1	-0
lib/firmware/fsm_msg_zcash.h	+3	-0
lib/firmware/home_sm.c	+10	-15
lib/firmware/recovery_cipher.c	+3	-1
lib/firmware/reset.c	+2	-0
lib/firmware/signing.c	+20	-13
unittests/firmware/fsm.cpp	+250	-30

Protected Ping and stale signing b770928ba

Ends an older signing session before a protected Ping can suspend it; adds a dedicated regression.

File	Added	Deleted
lib/firmware/fsm_msg_common.h	+11	-0
unittests/firmware/fsm.cpp	+13	-0

Top-level dispatch boundary 2bd12230f

Ends stale signing before a new top-level message is dispatched, in both parsed and raw message paths.

File	Added	Deleted
include/keepkey/board/messages.h	+1	-0
lib/board/messages.c	+12	-0
lib/firmware/fsm.c	+35	-0
lib/firmware/fsm_msg_common.h	+8	-7
unittests/firmware/fsm.cpp	+11	-0

Dispatch session authority d4aa26f91

Preserves the authority of the active session across dispatch boundaries and tests the failure and continuation paths.

File	Added	Deleted
lib/firmware/fsm.c	+53	-3
lib/firmware/fsm_msg_common.h	+5	-5
unittests/firmware/fsm.cpp	+52	-14

Cross-workflow acknowledgements c3ec59c35

Rejects acknowledgements from another workflow instead of allowing them to advance the active signer; adds regression coverage.

File	Added	Deleted
docs/release/audit-units/autolock-workflow-progress.md	+4	-2
include/keepkey/firmware/zcash.h	+1	-0
lib/firmware/ethereum.c	+13	-0
lib/firmware/fsm.c	+27	-2
lib/firmware/fsm_msg_zcash.h	+2	-0
unittests/emulator/CMakeLists.txt	+4	-1
unittests/firmware/fsm.cpp	+74	-0

Findings and evidence

- P02-001, P02-002 and P02-003 receipts record failure-before reproductions and focused passing native results. The exact candidate [CI run 34951131013](#) passed at 7e091af157131897adc5514de392570c32088946: full and Bitcoin-only ARM builds, unit suites and host integration, emulator builds, Python dylib, crypto, static analysis, formatting, submodule/secret checks, report generation and CI gate.
- 7e091af15. .614425a2a changes only CI workflow files. Firmware source, tests and dependency pointers are identical. The earlier run supports Block 2 behavior; it does not certify the later workflow refactor.
- F161: the packet-storage UDP regression is compiled only in the full variant. Bitcoin-only runs the tiny-message test and its complete native suite. Device USB callback paths were source reviewed and ARM built, but not exercised by that native regression.
- F204: a shared UDP port may cause test interference. The packet test consumes one datagram and restores the FSM callback before assertions; the exact candidate CI completed. Flakiness is a test risk to watch, not proven absent by one pass.
- F205: the local poll result is assigned from each synchronous call before its loop condition is read; no asynchronous writer modifies that local, so a `volatile` qualifier would not strengthen this check.

Remaining boundaries: physical USB/OLED and signed-upgrade checks are release gates, and the CI workflow refactor needs its own exact-head gate. This report does not claim hardware execution, product promotion or zero possible defects.

Questions for final review

1. Does any tiny-message rejection path still send two replies or leave a handler waiting?
2. Can a top-level or cross-workflow message retain authority over the previous signer after dispatch?
3. Do device-only USB callback paths clear packet bytes on every short and full read?
4. Should the shared-port test risk receive a dedicated isolation change before final product acceptance?